

Temas para o seminário

CST em Análise e Desenvolvimento de Sistemas

Prof. Emerson Ribeiro de Mello

mello@ifsc.edu.br

Licenciamento



Slides licenciados sob [Creative Commons "Atribuição 4.0 Internacional"](#)

Instruções para o seminário

1 Escolha um dos tópicos

- Trabalho em grupo de 3 pessoas, mas a avaliação é individual

2 Prepare uma apresentação

- Fazer uso de *slides*
- Duração máxima de 30 minutos

3 Prepare uma demonstração prática

- Fazer uso de ferramentas ou exemplos práticos
- Os demais alunos na sala devem poder acompanhar a demonstração em seus computadores
- Duração máxima de 30 minutos

Estrutura da apresentação

1 Introdução

- Contexto e relevância do tema

2 Desenvolvimento

- Explicação dos principais conceitos
- Exemplos teóricos

3 Demonstração prática

- Apresentar o cenário e a motivação da demonstração
- Falar quais ferramentas serão utilizadas

4 Conclusão

- Síntese do conteúdo e principais aprendizados

5 Referências

- Bibliografia utilizada
- Indicar se fez uso de LLM e como foi utilizado

Demonstração prática

- Faça uma introdução sobre o que será demonstrado
- Faça uma sequência de passos que possam ser seguidos pelos demais alunos na sala
- Se precisar de ferramentas que dependam de privilégios de administrador, então faça uso de contêineres Docker
- Após o término da demonstração, faça uma síntese dos resultados obtidos

Critérios de avaliação

- Clareza e profundidade da explicação
- Coerência e relevância da demonstração prática
- Capacidade de engajar a audiência e responder perguntas
- Participação de todos os membros do grupo
- Cumprimento do tempo de apresentação e da demonstração prática

! Cuidado

O texto dos slides deve ser original, ou seja, não pode ser copiado de outras fontes sem a devida citação. O uso de LLM pode ser feito para auxiliar na pesquisa e organização das ideias, mas o conteúdo final deve ser escrito pelos membros do grupo.

Tópicos

- 1 Oblivious DNS
- 2 Cofre de senhas (*vault*)
- 3 OWASP Juice Shop
- 4 OWASP WebGoat e WebWolf
- 5 OWASP ZAP
- 6 Burp Suite
- 7 mitmproxy
- 8 Hydra

Cofre de senhas (vault)

- Ferramenta de segurança que armazena e gerencia senhas, chaves de API, certificados e outros segredos de forma criptografada
 - Exemplos: HashiCorp Vault, Google Cloud Secret Manager, AWS Secrets Manager

Sugestão para demonstração prática

Mostrar como uma aplicação pode acessar um segredo armazenado no Vault, simulando uma situação em que a aplicação precisa acessar uma chave API sem que os desenvolvedores ou usuários finais tenham acesso direto à chave

Oblivious DNS

<https://blog.cloudflare.com/pt-br/oblivious-dns/>

- O ODNS é uma extensão do protocolo DNS que permite que os clientes consultem servidores DNS recursivos sem revelar o nome do domínio que estão consultando
- Nesta apresentação é necessário falar sobre
 - DNS tradicional
 - DNS-over-HTTPS (DoH)
 - DNS-over-TLS (DoT)
 - ODNS (Oblivious DNS)
 - ODoH (Oblivious DNS-over-HTTPS)

Sugestão para demonstração prática

Fazer uso de contêineres Docker para realizar uma demonstração prática de como configurar um servidor ODNS e um cliente ODoH

OWASP Juice Shop

<https://owasp.org/www-project-juice-shop/>

- Aplicação *web* vulnerável, propositalmente criada para fins de aprendizado e testes de segurança

Sugestão para demonstração prática

Realizar um ataque de Injeção de SQL ou XSS em uma aplicação vulnerável, depois demonstrar como corrigir a vulnerabilidade

OWASP WebGoat e WebWolf

<https://owasp.org/www-project-webgoat>

- Aplicação *web* vulnerável, propositalmente criada para fins de aprendizado e testes com vulnerabilidade comumente encontradas em aplicações baseadas em Java e que usam componentes *open source* populares

Sugestão para demonstração prática

Escolha uma vulnerabilidade do WebGoat e demonstre como explorá-la. Também demonstre o uso do WebWolf, que é uma aplicação que simula a máquina do atacante

- Ferramenta de segurança de aplicativos da *web*, usado para encontrar vulnerabilidades em aplicações *web*

Sugestão para demonstração prática

Executar uma varredura de vulnerabilidades e, em seguida, explorar uma das vulnerabilidades encontradas (injeção de SQL ou XSS) em uma aplicação *web* vulnerável (e.g. Juice Shop)

Burp suite

<https://portswigger.net/burp>

- Ferramenta de teste de segurança de aplicativos *web* que permite realizar testes manuais e automatizados

Sugestão para demonstração prática

Demonstrar ataque de força bruta com a ferramenta Burp Intruder em um formulário de *login*

- Ferramenta de interceptação de tráfego em modo *man-in-the-middle* (MITM), que permite visualizar, modificar e registrar o tráfego HTTP e HTTPS

Sugestão para demonstração prática

Configurar o mitmproxy para interceptar o tráfego de um site e capturar credenciais de login

Hydra

<https://github.com/vanhauser-thc/thc-hydra>

- Ferramenta de força bruta utilizada para testar a robustez de senhas em diversos serviços e protocolos, como SSH, FTP, MySQL, etc
- Permite realizar ataques automatizados tentando múltiplas combinações de usuários e senhas, utilizando listas personalizadas ou pré-definidas¹

Sugestão para demonstração prática

Demonstrar ataque de força bruta contra um servidor SSH ou MySQL, mostrando como identificar senhas fracas e discutir medidas de proteção

¹ <https://github.com/josamarcelc/common-password-list>